

网络安全实战课程

Cyber Practice Lab

南京航空航天大学·信息安全方向

赵彦超·陈兵

开始 →

课程信息

上课时间

周次	星期	节次
第 11-16 周	星期一	第 7-10 节
第 11-14 周	星期三	第 9-11 节
第 15-17 周	星期三	第 5-8 节

实验安排

- 共 12 个实验，每周在 QQ 群发布 2 个实验的密码，完成 2 个即可
- 实验在本地 Kali 环境（127.0.0.1）进行
- 无需在实验平台上提交，完成后在超星上传报告

重要原则：课程边界

- 1 △ 所有实验严格限制在 127.0.0.1 范围内
- 2
- 3 禁止扫描 campus 网络、同学主机或任何外部 IP
- 4
- 5 违规者将被终止实验资格并报告教务

为什么？

- 这是一个**隔离的本地实验环境**
- 攻击真实系统是**违法行为**（《网络安全法》第27条）
- 你的任务是**掌握防御技术**，不是伤害他人

课程概述

我们要做什么？

- 12 个黑客攻防实验，从零构建攻击者视角
- 真实漏洞靶场，而非模拟环境
- 完整攻击链：侦察 → 利用 → 横向 → 目标达成
- 技术报告写作，锻炼表达与复盘能力

你将掌握

工具

用途

nmap / curl

侦察与指纹识别

Burp Suite

Web 漏洞测试

Wireshark / tcpdump

流量分析与 C2 检测

实验环境架构

实验列表

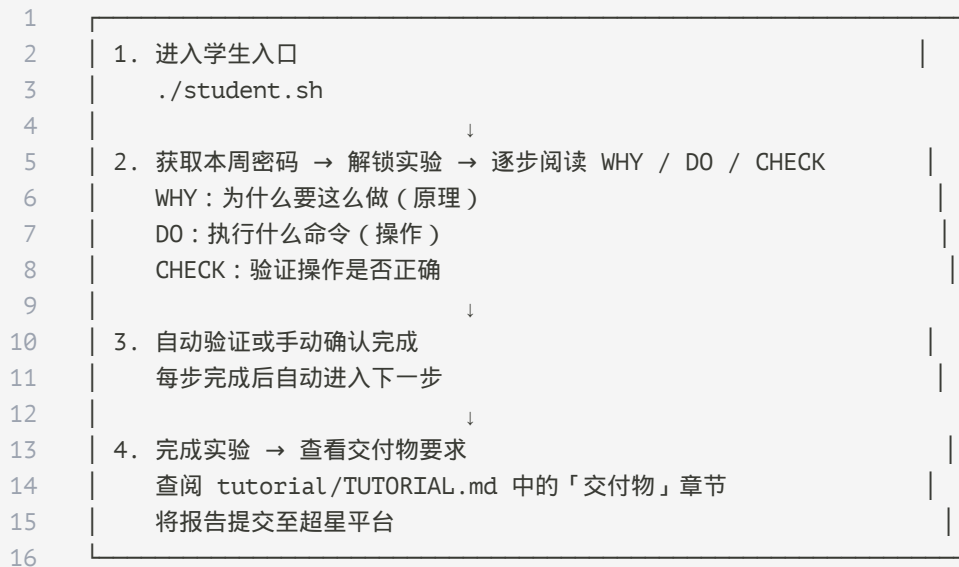
#	主题	核心技能	靶场
Lab01	侦察与资产发现	nmap 扫描、指纹识别	所有服务
Lab02	Web 信息泄露	目录发现、日志分析	nginx-lab
Lab03	认证审计	SSH 暴力破解、日志取证	ssh-lab
Lab04	SQL 注入	UNION 注入、盲注	Juice Shop / WebGoat
Lab05	XSS 与会话安全	CSP、Cookie 属性	Juice Shop / WebGoat
Lab06	文件上传漏洞	绕过、webshell	upload-lab
Lab07	命令注入	shell=True 危险、RCE	cmd-lab

快速上手：启动第一个实验

```
1  # 第一步：进入工作目录
2  cd ~/cyber-practice
3
4  # 第二步：安装环境（仅首次）
5  ./install-kali.sh
6
7  # 第三步：检查工具是否就绪
8  ./check-env.sh
9
10 # 第四步：进入学生入口（渐进式引导界面）
11 ./student.sh
```

□ `./student.sh` 会显示 TUI 菜单，输入密码解锁实验，即可逐步开始。

实验操作流程



提示：卡住时按 **h** 获取渐进式提示，最后才会看到完整答案。

靶场服务一览

服务	地址	说明
nginx-lab	<code>http://127.0.0.1:8082</code>	Web 信息泄露、备份目录
ssh-lab	<code>ssh student@127.0.0.1 -p 2222</code>	弱密码认证（密码：Student123）
upload-lab	<code>http://127.0.0.1:8086</code>	文件上传漏洞
cmd-lab	<code>http://127.0.0.1:8087</code>	命令注入 RCE
traffic-lab	<code>http://127.0.0.1:8089</code>	流量分析、C2 信标
incident-lab	<code>http://127.0.0.1:8092</code>	事件响应综合靶机
Juice Shop	<code>http://127.0.0.1:3000</code>	SQL 注入、XSS 靶场

实验报告要求

评分维度（100分）

维度	分值	要求
操作完成度	20	正确启动实验，完成核心任务
证据收集	25	截图、日志、命令输出完整
技术原理阐述	20	准确解释漏洞原理和攻击过程
防御方案	20	可行、完整、可落地
报告质量	15	结构清晰、分析深度

常见错误

工具速查

```
1  # 学生入口 (TUI 菜单, 逐步引导)
2  ./student.sh
3
4  # 启动实验 (如果不用 student.sh)
5  ./reset-lab.sh lab04
6
7  # 端口扫描
8  nmap -sS -p 3000,8080,8082,8086,2222 127.0.0.1
9
10 # HTTP 检测
11 curl -I http://127.0.0.1:8082/
12
13 # Docker 操作
14 docker compose ps
15 docker logs nginx-lab 2>&1 | tail -20
16
17 # 启动/停止实验
18 ./start-lab.sh lab04
19 ./stop-lab.sh
20 ./reset-lab.sh lab04
21
22 # 验证环境
23 ./verify-lab-env.sh
```

学习建议

进攻者思维

"你要知道攻击是怎么发生的，才能知道如何防御它。"

- 每个实验先理解攻击原理，再动手
- 关注攻击者的第一步是什么（侦察？弱口令？）
- 尝试理解攻击者的完整链条（侦察 → 初始访问 → 横向 → 目标）

防御者思维

- 做完攻击实验后，问自己：如果我是防守方，怎么发现这种攻击？
- 每个实验都要求你提出防御方案，这是核心输出

记录习惯

- 边做边截图，不要事后补
- 命令输出直接复制保存

常见问题

Q：工具报错 "permission denied"

```
1 # Docker 需要 root 权限
2 sudo docker compose up -d
3
4 # 或者将当前用户加入 docker 组（需要重新登录）
5 sudo usermod -aG docker $USER
6 newgrp docker
```

Q：服务启动后无法访问

```
1 # 重置实验
2 ./reset-lab.sh lab04
3
4 # 检查容器状态
5 docker compose ps
```

Q：实验手册的 jq 命令报错

```
1 # eve.json 是 NDJSON 格式，需要加 -s
2 jq -s '.[[] | .alert.signature' evidence/ids/eve.json
```

资源链接

漏洞数据库

- **CVE** : cve.mitre.org
- **NVD** : nvd.nist.gov
- **Exploit-DB** : exploit-db.com
- **OWASP Top 10** : owasp.org/www-project-top-ten
- **ATT&CK Matrix** : attack.mitre.org

实验手册

每个实验的 `TUTORIAL.md` 在对应目录下（需输入密码解锁）：

```
1 labs/lab01-recon/tutorial/TUTORIAL.md
2 labs/lab02-info-leak/tutorial/TUTORIAL.md
3 ...
```

下一步

现在开始

```
1 cd ~/cyber-practice
2 ./student.sh
```

阅读

- 解锁 `lab01-recon` 后阅读 `tutorial/TUTORIAL.md`
- 查看 `docs/diagrams/` （架构图、攻击链图）

有问题随时在 QQ 群提问 □